
Hunstanton Primary Audit Report

Audit Date: 16 December 2019

Report: Year 2 visit 2

DPE: Linda Mortimer

School member: Headteacher - Di Mapplebeck and School Support Manager

1. Visit details

Details highlighted at the time of the last visit were discussed. GDPR documents and policies were also reviewed. This included DPE Best Practice areas, Compliance Checklists, SLA tool, Record of Processing and Compliance Manager being discussed and demonstrated to the school. The themed audit carried out by NCC in Summer Term 2019 was also talked through (refer to section 7 below) as well as when the need arises for completing a Data Protection Impact Assessment (DPIA), (refer to section 6.1 below).

The Record of Processing tool was accessed and the process for managing admission paperwork was completed. The school has made good progress in the preparation for this next step in GDPR compliance and this will help DPE when they work with the school to complete the Record of Processing for their most common processes.

Review actions recommended at time of previous visit – 5.2.19 (Arienne Stanyon)

All items raised at the time of the previous audit have been addressed.

The school has introduced its own internal data protection audit procedure. GDPR walks taking place on a monthly basis using the DPE standard form for audit purposes and resulting feedback is provided at staff meetings.

2. Audit walk findings on 16.12.19

Signing-in arrangements: The school uses the Cherry Carbonless signing in system and all visitors are signposted to the school's Privacy Notice, on the school website.

For students arriving early or late, details are recorded on cards which are later stored securely in a locked cabinet.

Naming convention: All exercise books, work trays, files, displays and coat pegs use first names only.

Each classroom has a lockable cupboard where sensitive information is stored securely. Cupboards are locked at night.

Laptops: Those situated in the library and school hall can only access specific software relevant to their use and not able to view the wider school network.

School Kitchen: Operated by Norse Catering, there is a file for details of students with allergies and this is stored securely when not in use. However, there is a photo of a new student with a specific allergy on display at the inside of the serving hatch. This will be removed by the kitchen manager once staff are confident in their knowledge of the student's particular needs.

Student Care Plans: are stored in personal files which are kept in locked cabinets.

First Aid Records: are kept in the Food Tech room in an unlocked cupboard. Please remove previous records and retain securely ensuring that only the current day's records are in place at any one time.

Staffroom: Staff pigeon holes contained information going back to 2016, including student behavior reports and speech and language reports. The Headteacher does remind staff to empty pigeonholes on a regular basis, but storing information including personal information in such a way, is a significant risk and staff should be warned that such practices could have very serious consequences.

Photo Storage and Data Cleansing: This was discussed and a robust procedure for cleansing images from school iPads and cameras will be introduced. EYFS needs to be aware of the importance of regular cleansing and uploading of images taken using iPads / cameras to record student learning journeys. This will ensure that the minimum amount of images are stored on school devices at any one time.

School Server: The school is about to replace its server and move to cloud computing. At this time the school will review the data stored and cleanse or archive as necessary.

Printers / Photocopiers: The school photocopier has secure print access in place.

2. Compliance actions that should now be completed

Initial documents:

- Privacy Notice
- GDPR Policy
- Data Breach Procedure
- SAR procedure
- Photo and Video consent, guidelines and records

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

2.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016_IRMS_Toolkit_for_Schools_v5_Master.pdf
- DfE toolkit
https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

2.2. Staff training

GDPR training has been completed and documented for the majority of staff. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

2.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

2.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

3. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

4. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

5. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

5.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

6. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>